Partie 2.1 – Gestion des utilisateurs, des rôles et des privilèges

1. Objectif

Cette partie consiste à définir un mécanisme de gestion des utilisateurs, des rôles et des privilèges permettant de contrôler l'accès aux différentes fonctionnalités du système de gestion des inscriptions et des réinscriptions en doctorat.

Le modèle proposé distingue trois notions principales : l'utilisateur, le rôle et le privilège.

2. Description des classes

2.1. Utilisateur

La classe `Utilisateur` représente le compte technique permettant à une personne d'accéder au système.

Elle contient les informations nécessaires à l'authentification et à la gestion du compte, notamment son identifiant, le mot de passe haché, son statut, la date de création et les informations relatives à la dernière connexion.

Elle permet également de gérer l'activation, la désactivation, le blocage du compte ainsi que l'attribution et le retrait des rôles.

2.2. Role

La classe `Role` représente un profil d'accès associé à un utilisateur.

Exemples de rôles envisagés :

- CANDIDAT ;
- DOCTORANT ;
- ENCADRANT ;
- CO_ENCADRANT ;
- DIRECTEUR_STRUCTURE ;
- DIRECTEUR_CED ;
- AGENT_ADMINISTRATIF ;
- ADMINISTRATEUR.

Certains rôles sont directement liés aux acteurs identifiés dans les documents du projet. Le rôle ADMINISTRATEUR constitue une proposition de conception à confirmer.

2.3. Privilege

La classe `Privilege` représente une autorisation permettant d'effectuer une action sur une ressource du système.

Un privilège est défini par une ressource et une action. Par exemple, le privilège CANDIDATURE + VALIDER correspond à l'autorisation de valider une candidature.

Les privilèges sont associés aux rôles et non directement aux utilisateurs.

3. Associations et cardinalités

Deux associations plusieurs-à-plusieurs sont définies :

- Un utilisateur peut posséder plusieurs rôles et un même rôle peut être attribué à plusieurs utilisateurs.
- Un rôle peut posséder plusieurs privilèges et un même privilège peut être associé à plusieurs rôles.

L'association entre `Personne` et `Utilisateur` permet de distinguer l'identité métier du compte technique. Cette association doit rester cohérente avec le modèle conceptuel de la Partie 1.

4. Mécanisme de contrôle d'accès

Lorsqu'un utilisateur souhaite accéder à une fonctionnalité, le système vérifie :

1 Que son compte est actif.

2 Les rôles qui lui sont attribués.

3 Les privilèges associés à ces rôles.

4 Que l'action demandée est autorisée sur la ressource concernée.

5 Que l'utilisateur a accès aux données concernées selon les relations métier définies dans la Partie 1.

L'accès est refusé lorsque les conditions d'autorisation ne sont pas satisfaites.

5. Principales règles de gestion

- Un utilisateur peut posséder plusieurs rôles.
- Un rôle peut être attribué à plusieurs utilisateurs.
- Les privilèges sont associés aux rôles.
- L'adresse e-mail utilisée comme identifiant de connexion doit être unique.
- Le mot de passe doit être stocké sous une forme hachée et non en clair.
- Un compte possède un statut permettant de gérer son activation et sa disponibilité.
- L'accès aux fonctionnalités est conditionné par les privilèges associés aux rôles de l'utilisateur.
- Les rôles et les privilèges doivent être gérés de manière cohérente avec les responsabilités des acteurs du système.

Les règles relatives au blocage, à la réactivation et à l'administration des comptes constituent des choix de conception lorsque les documents ne précisent pas leur fonctionnement exact.

6. Conclusion

Le diagramme de classes détaillé proposé permet de représenter la gestion des utilisateurs, des rôles et des privilèges. Il constitue une base pour l'implémentation du contrôle d'accès au sein du système, tout en séparant les comptes techniques des responsabilités métier.

Partie 2.1 – Gestion des utilisateurs, des rôles et des privilèges

